

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ



ΠΑΝΕΠΙΣΤΗΜΙΟ
ΔΥΤΙΚΗΣ ΑΤΤΙΚΗΣ
UNIVERSITY OF WEST ATTICA

ΤΜΗΜΑ ΜΗΧΑΝΙΚΩΝ ΠΛΗΡΟΦΟΡΙΚΗΣ ΚΑΙ
ΥΠΟΛΟΓΙΣΤΩΝ

TASK 5 TLS SCANNING

STUDENT DETAILS

NAME: ATHANASIOU VASILIOS EVANGELOS REGISTER
NUMBER: 19390005 **STUDENT**
SEMESTER: 8th **STUDENT**
STATUS: UNDERGRADUATE **PROGRAM OF**
STUDY: PADA **LABORATORY**
DEPARTMENT: ASF 05 WEDNESDAY 12:00 – 14:00
LABORATORY HEAD: GEORGOULAS ANGELOS **DELIVERY**
DATE: 18/6/2023

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

STUDENT PHOTO:



ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

CONTENTS

<u>Laboratory Environment</u>	<u>(PAGE 4)</u>
<u>1. TLS Scanning in online stores</u>	<u>(PAGES 5 – 10)</u>
Website	(PAGE 5)
Research from the web tool	(PAGES 5 – 8)
Research from the installed tool Agreements and disagreements of the tools	(PAGES 8 – 9) (PAGE 10)
<u>2. TLS Scanning on news sites</u>	<u>(PAGES 10 – 17)</u>
Website	(PAGE 10)
Research from the web tool	(PAGES 1 – 15)
Research from the installed tool Agreements and disagreements of the tools	(PAGES 15 – 16) (PAGE 17)
<u>3. TLS Scanning on University sites</u>	<u>(PAGES 17 – 24)</u>
Website	(PAGE 17)
Research from the web tool	(PAGES 18 – 22)
Research from the installed tool Agreements and disagreements of the tools	(PAGES 22 – 23) (PAGE 24)
<u>4. TLS Scanning of suspicious website</u>	<u>(PAGES 24 – 30)</u>
Website	(PAGE 24)
Research from the web tool	(PAGES 25 – 29)
Research from the installed tool Agreements and disagreements of the tools	(PAGES 29 – 30) (PAGE 30)

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

ACTIVITIES

Laboratory Environment

The activities were performed on a Linux virtual machine, specifically on Ubuntu 22.04. The tools used to detect any vulnerabilities in the TLS protocol supported by a website are:

1. <https://www.ssllabs.com/ssltest/> which is a web tool
2. <https://linuxsecurity.expert/security-tools/ssl-tls-scanners> the A2SV tool which is a python2 script that detects, through python2 libraries, any vulnerabilities of a website regarding the TLS protocol

SSL/TLS scanners

Tools

Popular SSL/TLS scanners

A2SV (SSL vulnerability scanner)

vulnerability scanning, vulnerability testing

A2SV is short for Auto Scanning to SSL Vulnerability, a security tool to scan for SSL and TLS vulnerabilities. It can be used during security assessments.

CRIME

DROWN

FREAK

HeartBleed

LOGJAM

The command executed to investigate the website by the installed tool is

```
python2 a2sv.py -t IP Address
```

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

1. TLS Scanning in online stores

Web page

For the purpose of the activity, the site <https://www.e-shop.gr/> was used. electronic store, in order to check its reliability in the TLS protocol.

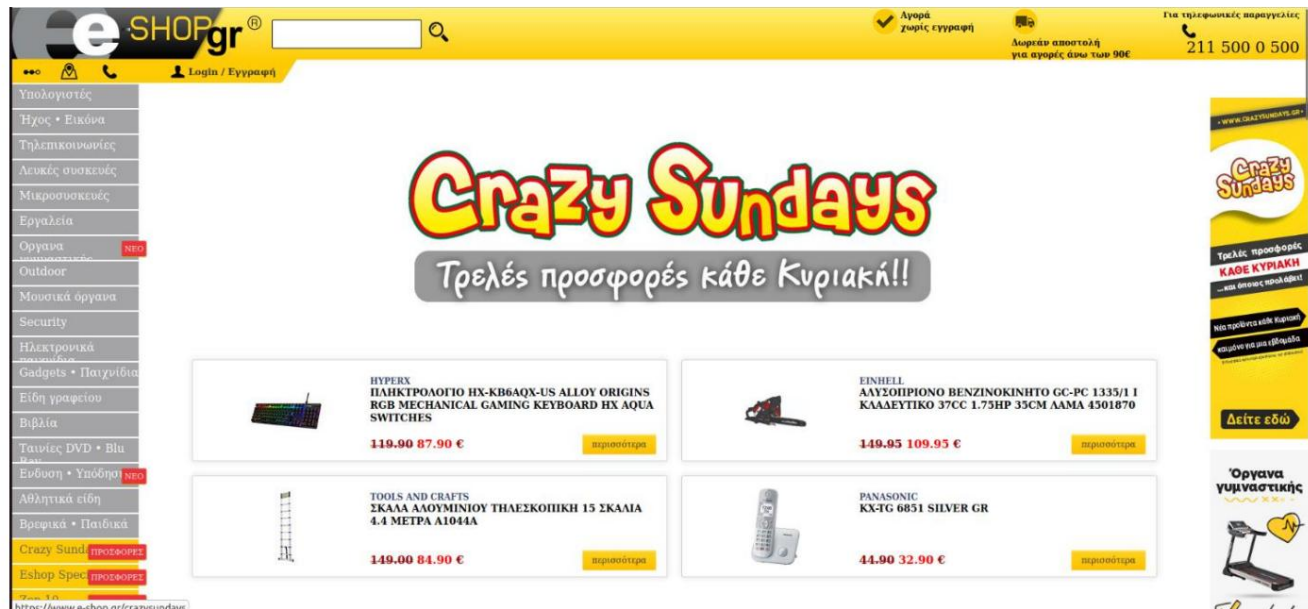


Figure 1.1. The e-shop website

Research from the web tool

Initially, we used the web tool <https://www.ssllabs.com/ssltest/>.

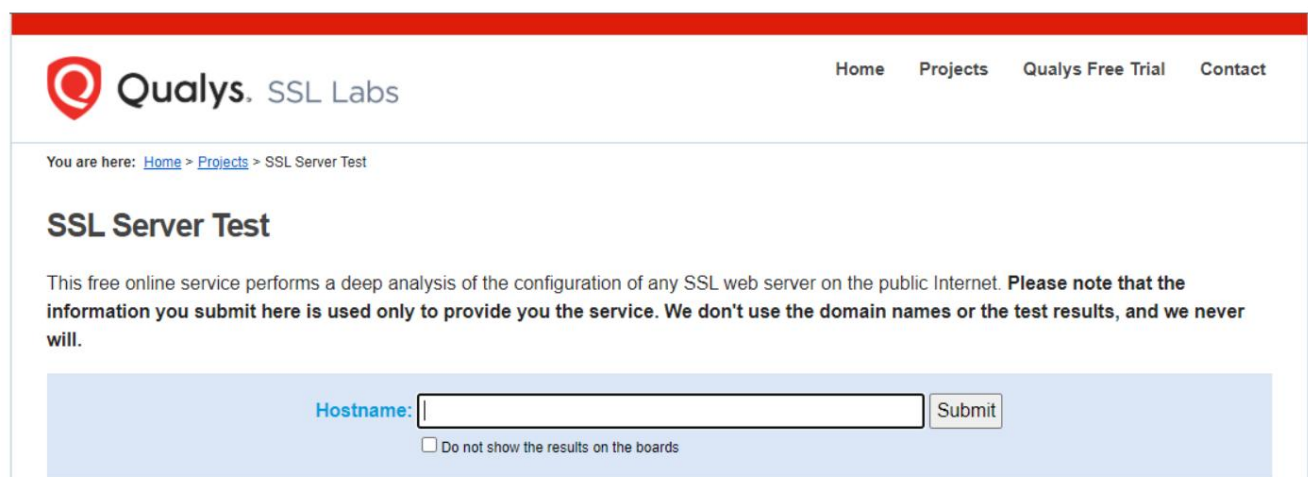


Figure 1.2. The SSL Labs web tool

We entered the website URL in the Hostname field provided by the tool and saw the results of the investigation and the website's digital certificates at <https://www.ssllabs.com/ssltest/analyze.html?d=www.e-shop.gr>.

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

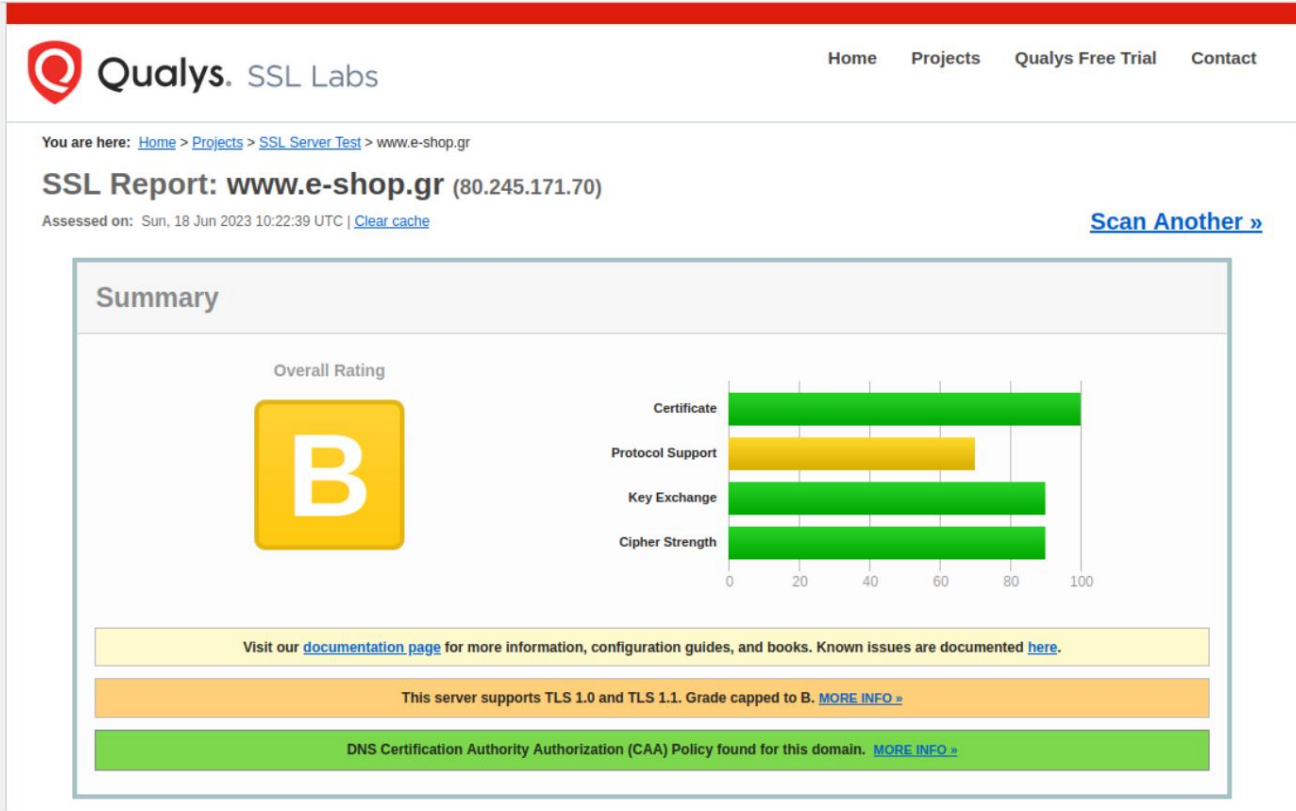


Figure 1.3. The results of the web tool survey

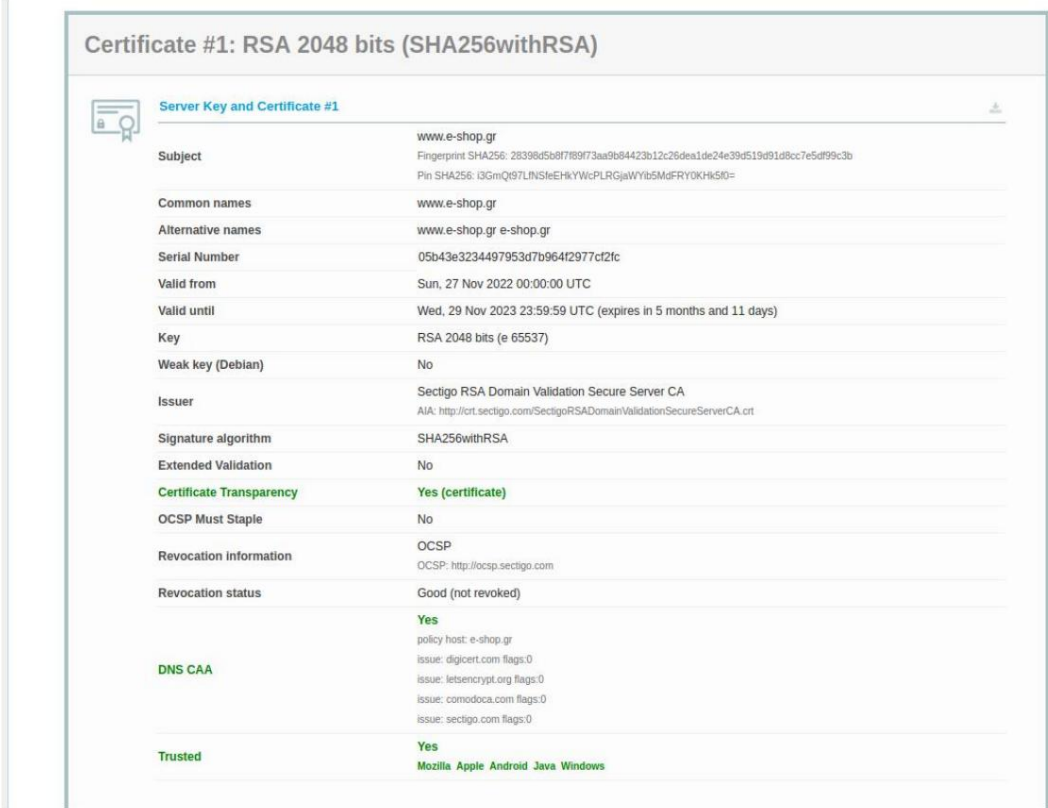


Figure 1.4. The server's digital certificate

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

The research showed that the website's reliability grade for the TLS protocol is "B", which means that it has a vulnerability, specifically in "Protocol Support", which is in yellow (unlike the others which are green in the bar graph next to the grade). We looked for more information in the field that says:

"The server supports TLS 1.0 and TLS 1.1. Grade capped to B. MORE INFO"

and specifically in the article https://blog.qualys.com/product-tech/2017/03/13/caa-mandated-by-cabrowser-forum?_ga=2.204699411.2017122474.1687046115-1545449628.1687046115

SSL Labs Grade Change for TLS 1.0 and TLS 1.1 Protocols



Yash Sannegowda
November 19, 2018 - 4 min read

👍 49

Last updated on: December 16, 2022



Update 1/31/2020: The grade change is now live on www.ssllabs.com. Servers that support TLS 1.0 or TLS 1.1 are capped to B grade.

Update 1/16/2020: The grade change is now live on the development server at dev.ssllabs.com. Servers that support TLS 1.0 or TLS 1.1 are capped to B grade on the development server. Deployment to production SSL Labs servers is planned for the very end of January.

Update 10/11/19: The TLS 1.0/1.1 warning changes are now live on www.ssllabs.com. The grade change for supporting TLS 1.0/1.1 is changed from March 2020 to January 2020 as shown below in the "SSL Labs Grade Change" section below and as reflected in the summary messages in SSL Labs results.

Update 11/30/18: Now live on ssllabs.com: In Configuration->Protocols section "TLS 1.1" text color will be changed to Orange by end of November 2018.

Figure 1.5. Website vulnerability information in the "Protocol Support" field

The article mentions websites that support older versions of TLS that had some vulnerabilities, which have been fixed in the latest version, TLS 1.3. Hence the "B" grade from the research tool. Finally, we saw the analysis of the protocol versions and cipher suites supported by this website.

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

 Protocols		
TLS 1.3		No
TLS 1.2		Yes
TLS 1.1		Yes
TLS 1.0		Yes
SSL 3		No
SSL 2		No
 Cipher Suites		
# TLS 1.2 (suites in server-preferred order)		
TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 (0xc02f)	ECDH secp256r1 (eq. 3072 bits RSA) FS	128
TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 (0xc030)	ECDH secp256r1 (eq. 3072 bits RSA) FS	256
TLS_DHE_RSA_WITH_AES_128_GCM_SHA256 (0x9e)	DH 2048 bits FS	128
TLS_DHE_RSA_WITH_AES_256_GCM_SHA384 (0x9f)	DH 2048 bits FS	256
TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA256 (0xc027)	ECDH secp256r1 (eq. 3072 bits RSA) FS WEAK	128
TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA (0xc013)	ECDH secp256r1 (eq. 3072 bits RSA) FS WEAK	128
TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384 (0xc028)	ECDH secp256r1 (eq. 3072 bits RSA) FS WEAK	256
TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA (0xc014)	ECDH secp256r1 (eq. 3072 bits RSA) FS WEAK	256
TLS_DHE_RSA_WITH_AES_128_CBC_SHA256 (0x67)	DH 2048 bits FS WEAK	128
TLS_DHE_RSA_WITH_AES_256_CBC_SHA256 (0x6b)	DH 2048 bits FS WEAK	256
TLS_RSA_WITH_AES_128_GCM_SHA256 (0x9c)	WEAK	128
TLS_RSA_WITH_AES_256_GCM_SHA384 (0x9d)	WEAK	256
TLS_RSA_WITH_AES_128_CBC_SHA256 (0x3c)	WEAK	128
TLS_RSA_WITH_AES_256_CBC_SHA256 (0x3d)	WEAK	256
TLS_RSA_WITH_AES_128_CBC_SHA (0x2f)	WEAK	128
TLS_RSA_WITH_AES_256_CBC_SHA (0x35)	WEAK	256
TLS_RSA_WITH_3DES_EDE_CBC_SHA (0xa)	WEAK	112
# TLS 1.1 (suites in server-preferred order)		
# TLS 1.0 (suites in server-preferred order)		

Figure 1.6. Analysis of protocol versions and cipher suites

Research from the installed tool

First, we opened the machine's terminal and moved to the directory where the python2 script is located with the command

```
cd a2sv
```

From Figure 1.3, we took the IP Address of the website and put it as a parameter to run the command:

```
python2 a2sv.py -t 80.245.171.70
```

Then, we saw the results of the research.

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

```
[A2SV REPORT]
[TARGET]: 80.245.171.70
[PORT]: 443
[SCAN TIME]: 2023-06-18 19:16:33.167040
[VULNERABILITY]
Vulnerability    CVE          CVSS v2 Base Score    State
=====
Anonymous Cipher CVE-2007-1858 AV:N/AC:H/Au:N/C:P/I:N/A:N Vulnerable!
CRIME(SPDY)      CVE-2012-4929 AV:N/AC:H/Au:N/C:P/I:N/A:N Vulnerable!
HeartBleed       CVE-2014-0160 AV:N/AC:L/Au:N/C:P/I:N/A:N Not Vulnerable.
CCS Injection    CVE-2014-0224 AV:N/AC:M/Au:N/C:P/I:P/A:P Not Vulnerable.
SSLv3 POODLE     CVE-2014-3566 AV:N/AC:M/Au:N/C:P/I:N/A:N Not Vulnerable.
OpenSSL FREAK    CVE-2015-0204 AV:N/AC:M/Au:N/C:N/I:P/A:N Not Vulnerable.
OpenSSL LOGJAM   CVE-2015-4000 AV:N/AC:M/Au:N/C:N/I:P/A:N Not Vulnerable.
SSLv2 DROWN      CVE-2016-0800 AV:N/AC:M/Au:N/C:P/I:N/A:N Not Vulnerable.

[FIN] Scan Finish!
```

Figure 1.7. The results of the summary survey of the installed tool

The research showed that the website is vulnerable to Anonymous Cipher and CRIME attacks, and this is due to the fact that it supports old versions of TLS. Finally, we saw the research's detailed checks for each type of attack that the tool checks for (CRIME, DROWN, FREAK, HeartBleed, LOGJAM).

```
GREEN
[INF] Check the SSL..
[RES] This target supports SSL..
[INF] Scan Anonymous Cipher..
- [LOG] IP Check Ok.
- [LOG] Start SSL Connection
- [LOG] Analysis SSL Information
- [LOG] 'Connection fail'
[INF] Scan CRIME(SPDY)..
- [LOG] IP Check Ok.
- [LOG] Start SSL Connection
- [LOG] Analysis SSL Information
- [LOG] 'Includes SPDY version <4'
[INF] Scan CCS Injection..
- [LOG] TLSv1.2 80.245.171.70:443 rejected early CCS
- [LOG] TLSv1.1 80.245.171.70:443 rejected early CCS
- [LOG] TLSv1 80.245.171.70:443 rejected early CCS
- [LOG] [SSLv3] 80.245.171.70:443 Invalid handshake.
[INF] Scan HeartBleed..
- [LOG] Sending Client Hello...
- [LOG] Waiting for Server Hello...
- [LOG] Sending heartbeat request..
[INF] Scan SSLv3 POODLE..
- [LOG] Invalid SSLv3 handshake.
[INF] Scan OpenSSL FREAK..
- [LOG] IP Check Ok.
- [LOG] Start SSL Connection / Gathering Information
- [LOG] Ending Get Information
- [LOG] 'Cipher is EXP' not in Response
[INF] Scan OpenSSL LOGJAM..
- [LOG] IP Check Ok.
- [LOG] Start SSL Connection / Gathering Information
- [LOG] Ending Get Information
- [LOG] 'Cipher is DEH' not in Response
[INF] Scan SSLv2 DROWN..
- [LOG] Not connected SSLv2
[RES] Finish scan all vulnerability..
```

Figure 1.8. The results of the analytical research of the installed tool

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

Agreements and disagreements of the tools

The web tool performs more extensive checks than the installed one, but both tools still agree that the website has vulnerabilities due to supporting older versions of TLS.

2. TLS Scanning on news sites

Web page

For the purpose of the activity, the site <https://www.newsbomb.gr/> was used.
news site, in order to check its reliability in the TLS protocol.

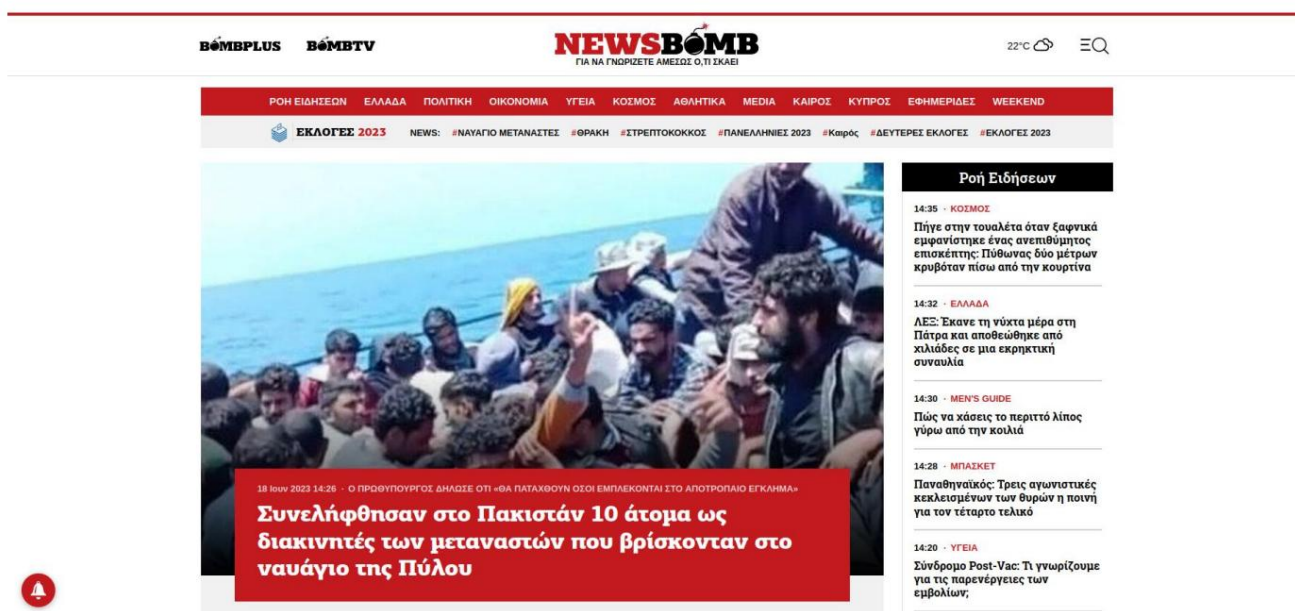


Figure 2.1. The news site website, newsbomb

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

Research from the web tool

Initially, we used the web tool <https://www.ssllabs.com/ssltest/>.



Qualys SSL Labs

[Home](#) [Projects](#) [Qualys Free Trial](#) [Contact](#)

You are here: [Home](#) > [Projects](#) > SSL Server Test

SSL Server Test

This free online service performs a deep analysis of the configuration of any SSL web server on the public Internet. **Please note that the information you submit here is used only to provide you the service. We don't use the domain names or the test results, and we never will.**

Hostname:

Submit

☐ Do not show the results on the boards

Figure 2.2. The SSL Labs web tool

We put the website URL in the Hostname field provided by the tool and saw the search results and the website's digital certificates in <https://www.ssllabs.com/ssltest/analyze.html?d=www.newsbomb.gr>.



Qualys SSL Labs

[Home](#) [Projects](#) [Qualys Free Trial](#) [Contact](#)

You are here: [Home](#) > [Projects](#) > [SSL Server Test](#) > [www.newsbomb.gr](#)

SSL Report: www.newsbomb.gr

Assessed on: Sun, 18 Jun 2023 11:51:26 UTC | [Hide](#) | [Clear cache](#)

[Scan Another >>](#)

	Server	Test time	Grade
1	23.48.99.144 a23-48-99-144.deploy.static.akamaitechnologies.com Ready	Sun, 18 Jun 2023 11:39:35 UTC Duration: 177.265 sec	B
2	2600:1418:a000:9:0:0:1728:6313 g2600-1418-a000-0009-0000-0000-1728-6313.deploy.static.akamaitechnologies.com Ready	Sun, 18 Jun 2023 11:42:32 UTC Duration: 178.177 sec	B
3	2600:1418:a000:9:0:0:1728:6303 g2600-1418-a000-0009-0000-0000-1728-6303.deploy.static.akamaitechnologies.com Ready	Sun, 18 Jun 2023 11:45:31 UTC Duration: 178.149 sec	B
4	23.48.99.142 a23-48-99-142.deploy.static.akamaitechnologies.com Ready	Sun, 18 Jun 2023 11:48:29 UTC Duration: 176.790 sec	B

SSL Report v2.1.10

Figure 2.3. The results of the web tool survey

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

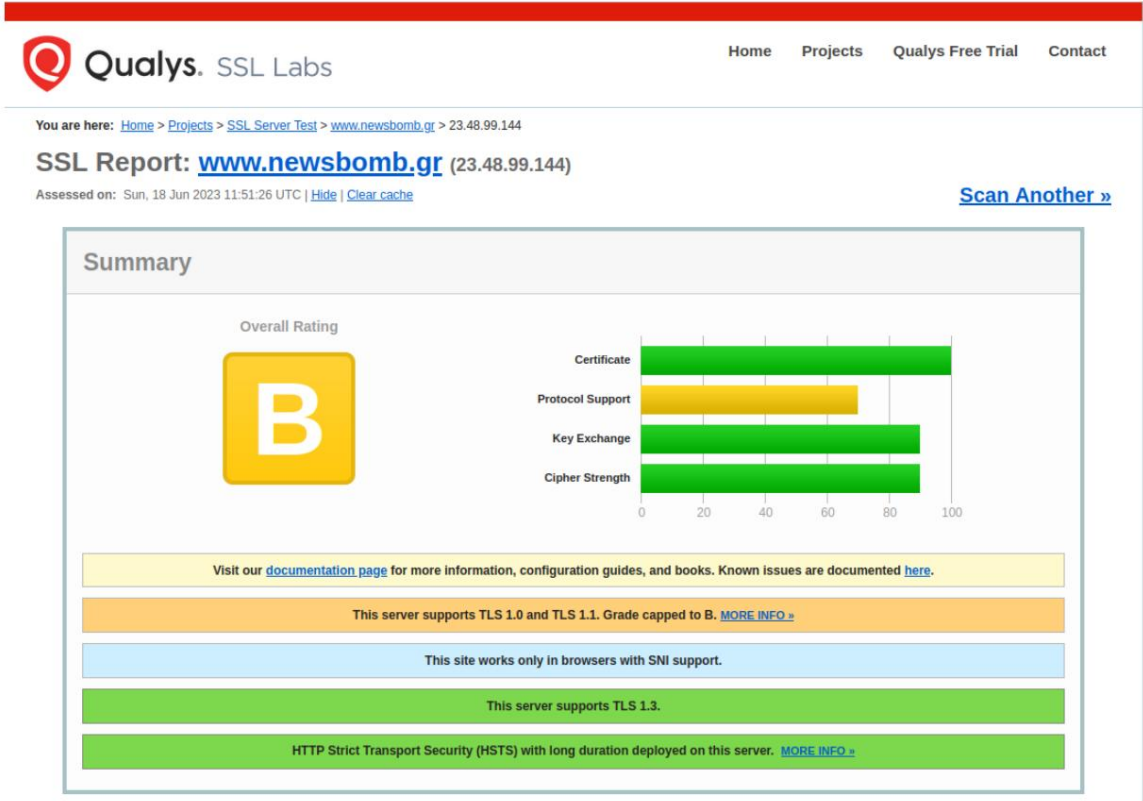


Figure 2.4. The results of the web tool's research for the 1st IP Address

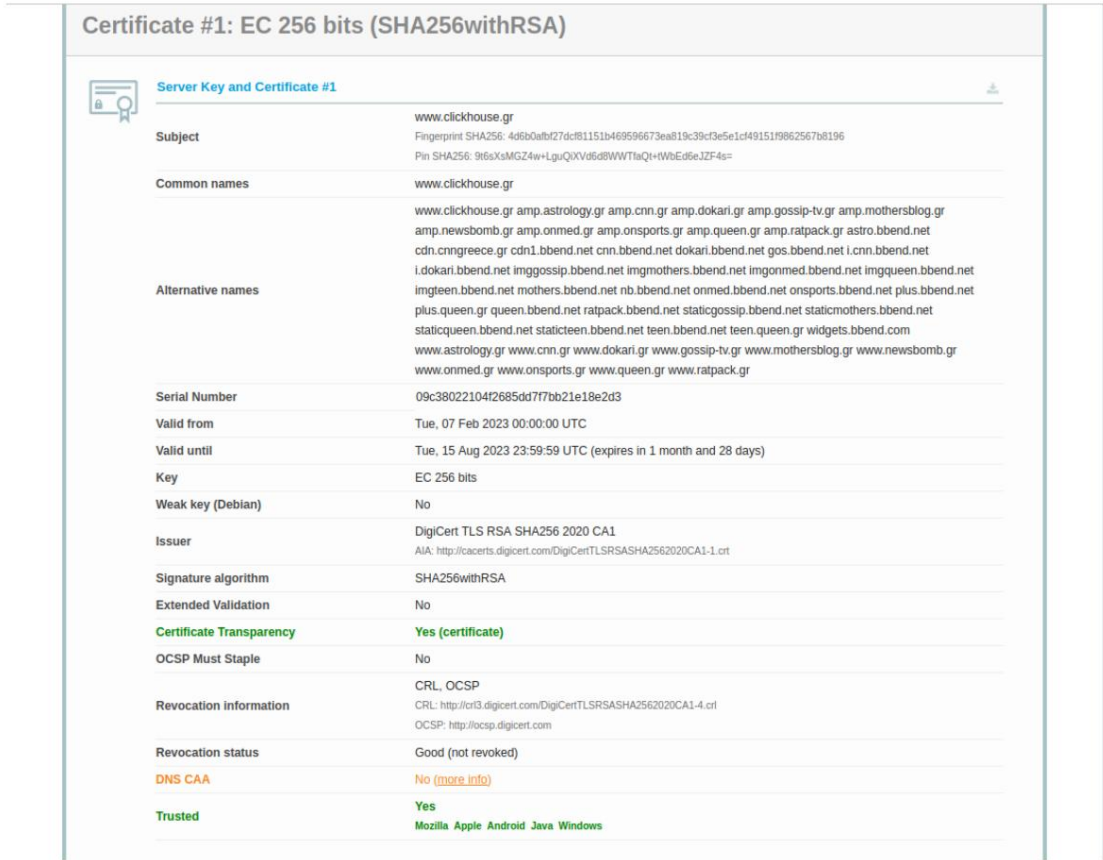


Figure 2.5. The 1st digital server certificate

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

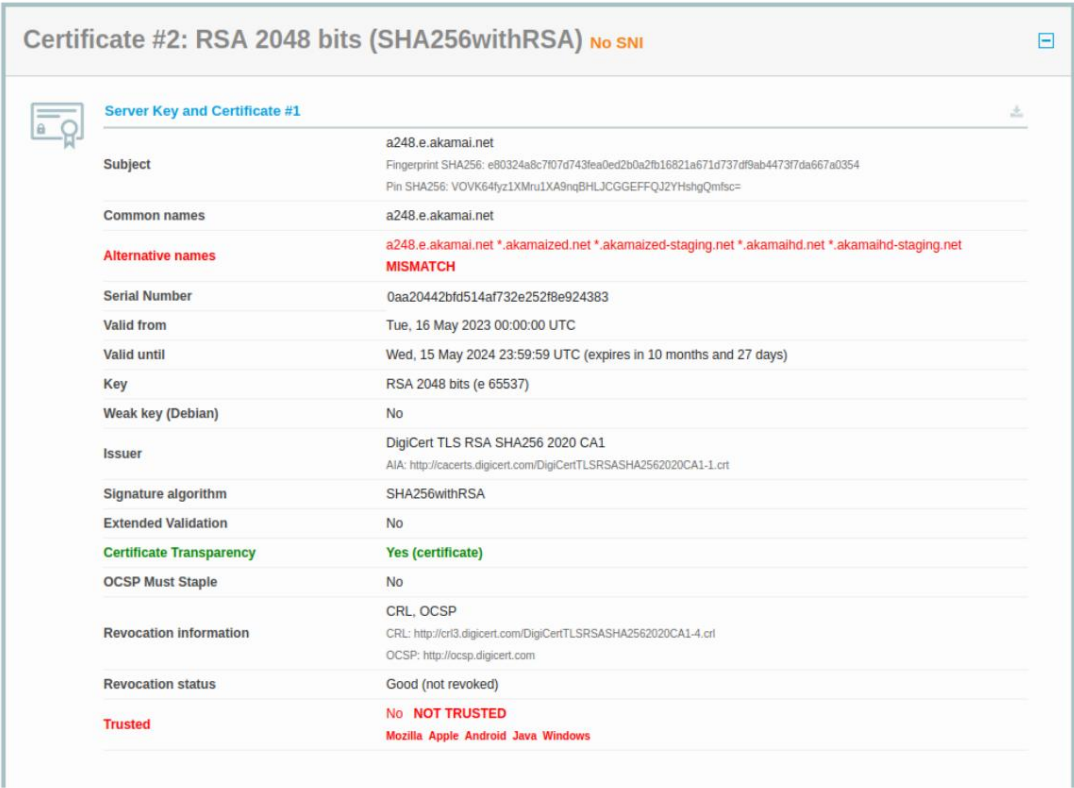


Figure 2.6. The 2nd digital certificate of the server

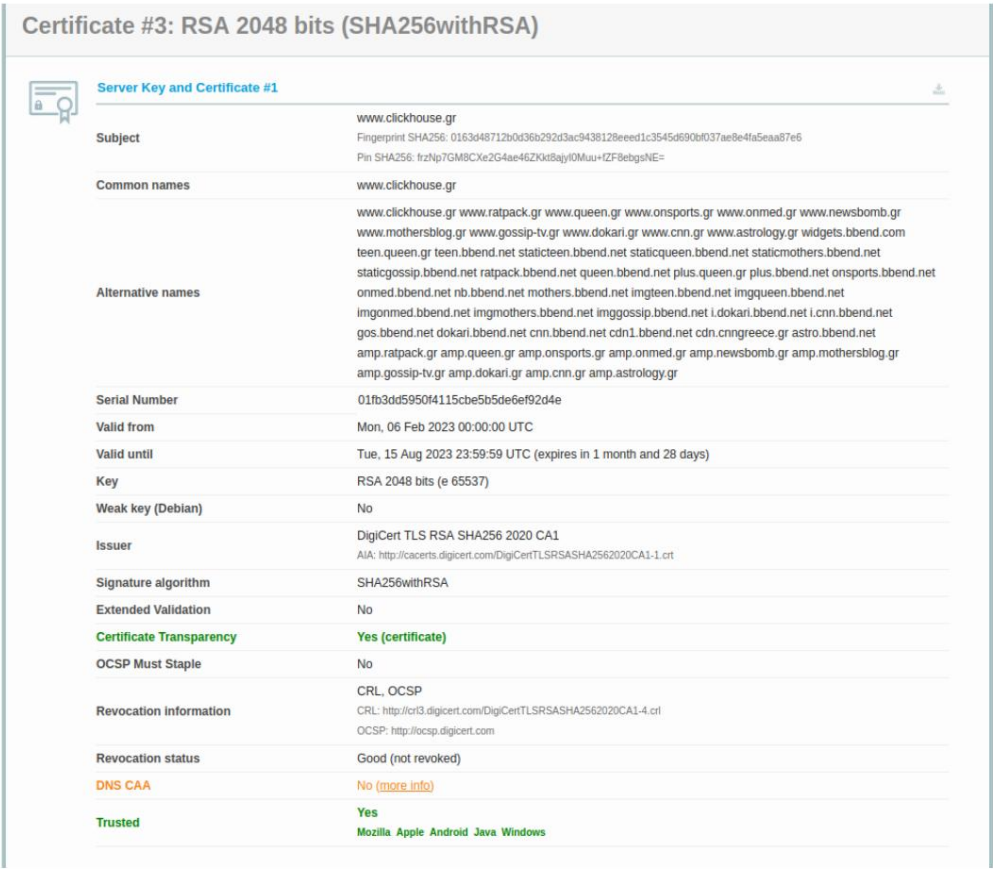


Figure 2.7. The 3rd digital server certificate

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

The research showed that the website's reliability level regarding the TLS protocol is "B" for each IP Address it has (we chose the 1st one only for the research), which means that it presents a vulnerability, specifically in "Protocol Support" which is in yellow (unlike the others which are green in the bar graph next to the level). We searched for more information in the field that says :

"The server supports TLS 1.0 and TLS 1.1. Grade capped to B. MORE INFO"

and specifically in the article https://blog.qualys.com/product-tech/2017/03/13/caa-mandated-by-cabrowser-forum?_ga=2.204699411.2017122474.1687046115-1545449628.1687046115

SSL Labs Grade Change for TLS 1.0 and TLS 1.1 Protocols



Yash Sannegowda
November 19, 2018 - 4 min read

👍 49

Last updated on: December 16, 2022



Update 1/31/2020: The grade change is now live on www.ssllabs.com. Servers that support TLS 1.0 or TLS 1.1 are capped to B grade.

Update 1/16/2020: The grade change is now live on the development server at dev.ssllabs.com. Servers that support TLS 1.0 or TLS 1.1 are capped to B grade on the development server. Deployment to production SSL Labs servers is planned for the very end of January.

Update 10/11/19: The TLS 1.0/1.1 warning changes are now live on www.ssllabs.com. The grade change for supporting TLS 1.0/1.1 is changed from March 2020 to January 2020 as shown below in the "SSL Labs Grade Change" section below and as reflected in the summary messages in SSL Labs results.

Update 11/30/18: Now live on ssllabs.com: In Configuration->Protocols section "TLS 1.1" text color will be changed to Orange by end of November 2018.

Figure 2.8. Website vulnerability information in the "Protocol Support" field

The article mentions websites that support older versions of TLS that had some vulnerabilities, which have been fixed in the latest version, TLS 1.3. Hence the "B" grade from the research tool. Finally, we saw the analysis of the protocol versions and cipher suites supported by this website.

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

		Protocols	
	TLS 1.3		Yes
	TLS 1.2		Yes*
	TLS 1.1		Yes
	TLS 1.0		Yes*
	SSL 3		No
	SSL 2		No
	(*) Experimental: Server negotiated using No-SNI		
		Cipher Suites	
	# TLS 1.3 (suites in server-preferred order)		
	TLS_AES_256_GCM_SHA384 (0x1302)	ECDH x25519 (eq. 3072 bits RSA) FS	256
	TLS_CHACHA20_POLY1305_SHA256 (0x1303)	ECDH x25519 (eq. 3072 bits RSA) FS	256 ^P
	TLS_AES_128_GCM_SHA256 (0x1301)	ECDH x25519 (eq. 3072 bits RSA) FS	128
	TLS_AES_128_CCM_8_SHA256 (0x1305)	ECDH x25519 (eq. 3072 bits RSA) FS	128
	TLS_AES_128_CCM_SHA256 (0x1304)	ECDH x25519 (eq. 3072 bits RSA) FS	128
	# TLS 1.2 (suites in server-preferred order)		
	TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384 (0xc02c)	ECDH secp256r1 (eq. 3072 bits RSA) FS	256
	TLS_ECDHE_ECDSA_WITH_AES_128_GCM_SHA256 (0xc02b)	ECDH secp256r1 (eq. 3072 bits RSA) FS	128
	TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 (0xc030)	ECDH secp256r1 (eq. 3072 bits RSA) FS	256
	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 (0xc02f)	ECDH secp256r1 (eq. 3072 bits RSA) FS	128
	TLS_ECDHE_ECDSA_WITH_CHACHA20_POLY1305_SHA256 (0xcca9)	ECDH secp256r1 (eq. 3072 bits RSA) FS	256 ^P
	TLS_ECDHE_RSA_WITH_CHACHA20_POLY1305_SHA256 (0xcca8)	ECDH secp256r1 (eq. 3072 bits RSA) FS	256 ^P
	TLS_ECDHE_ECDSA_WITH_AES_256_CBC_SHA384 (0xc024)	ECDH secp256r1 (eq. 3072 bits RSA) FS WEAK	256
	TLS_ECDHE_ECDSA_WITH_AES_128_CBC_SHA256 (0xc023)	ECDH secp256r1 (eq. 3072 bits RSA) FS WEAK	128
	TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384 (0xc028)	ECDH secp256r1 (eq. 3072 bits RSA) FS WEAK	256
	TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA256 (0xc027)	ECDH secp256r1 (eq. 3072 bits RSA) FS WEAK	128
	TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA (0xc014)	ECDH secp256r1 (eq. 3072 bits RSA) FS WEAK	256
	TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA (0xc013)	ECDH secp256r1 (eq. 3072 bits RSA) FS WEAK	128

Figure 2.9. Analysis of protocol versions and cipher suites

Research from the installed tool

First, we opened the machine's terminal and moved to the directory where the python2 script is located with the command

```
cd a2sv
```

From Figure 2.4, we took the IP Address of the website and put it as a parameter to run the command:

```
python2 a2sv.py -t 23.48.99.144
```

Then, we saw the results of the research.

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

```

-----[A2SV REPORT]-----
[TARGET]: 23.48.99.144
[PORT]: 443
[SCAN TIME]: 2023-06-18 19:19:05.195292
[VULNERABILITY]
Vulnerability      CVE              CVSS v2 Base Score      State
=====
Anonymous Cipher   CVE-2007-1858    AV:N/AC:H/Au:N/C:P/I:N/A:N Not Vulnerable.
CRIME(SPDY)        CVE-2012-4929    AV:N/AC:H/Au:N/C:P/I:N/A:N Vulnerable!
HeartBleed         CVE-2014-0160    AV:N/AC:L/Au:N/C:P/I:N/A:N Not Vulnerable.
CCS Injection      CVE-2014-0224    AV:N/AC:M/Au:N/C:P/I:P/A:P Not Vulnerable.
SSLv3 POODLE       CVE-2014-3566    AV:N/AC:M/Au:N/C:P/I:N/A:N Not Vulnerable.
OpenSSL FREAK      CVE-2015-0204    AV:N/AC:M/Au:N/C:N/I:P/A:N Not Vulnerable.
OpenSSL LOGJAM     CVE-2015-4000    AV:N/AC:M/Au:N/C:N/I:P/A:N Not Vulnerable.
SSLv2 DROWN        CVE-2016-0800    AV:N/AC:M/Au:N/C:P/I:N/A:N Exception
-----
[FIN] Scan Finish!

```

Figure 2.10. The results of the summary survey of the installed tool

The research showed that the website is vulnerable to CRIME-type attacks and this is due to the fact that it supports old versions of TLS. Finally, we saw the research's detailed checks for each type of attack that the tool checks for (CRIME, DROWN, FREAK, HeartBleed, LOGJAM).

```

GREEN
[INF] Check the SSL..
[RES] This target supports SSL..
[INF] Scan Anonymous Cipher..
- [LOG] IP Check Ok.
- [LOG] Start SSL Connection
- [LOG] Analysis SSL Information
- [LOG] 'Connection success'
[INF] Scan CRIME(SPDY)..
- [LOG] IP Check Ok.
- [LOG] Start SSL Connection
- [LOG] Analysis SSL Information
- [LOG] 'Includes SPDY version <4'
[INF] Scan CCS Injection..
- [LOG] TLSv1.2 23.48.99.144:443 rejected early CCS
- [LOG] TLSv1.1 23.48.99.144:443 rejected early CCS
- [LOG] TLSv1 23.48.99.144:443 rejected early CCS
- [LOG] [SSLv3] 23.48.99.144:443 Invalid handshake.
[INF] Scan HeartBleed..
- [LOG] Sending Client Hello...
- [LOG] Waiting for Server Hello...
- [LOG] Sending heartbeat request..
[INF] Scan SSLv3 POODLE..
- [LOG] Invalid SSLv3 handshake.
[INF] Scan OpenSSL FREAK..
- [LOG] IP Check Ok.
- [LOG] Start SSL Connection / Gathering Information
- [LOG] Ending Get Information
- [LOG] 'Cipher is EXP' not in Response
[INF] Scan OpenSSL LOGJAM..
- [LOG] IP Check Ok.
- [LOG] Start SSL Connection / Gathering Information
- [LOG] Ending Get Information
- [LOG] 'Cipher is DEH' not in Response
[INF] Scan SSLv2 DROWN..
invalid literal for int() with base 16: ''
[RES] Finish scan all vulnerability..

```

Figure 2.9. The results of the analytical research of the installed tool

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

Agreements and disagreements of the tools

The web tool performs more extensive checks than the installed one, but both tools still agree that the website has vulnerabilities due to supporting older versions of TLS.

3. TLS Scanning on University sites

Web page

For the purpose of the activity, the university site was used.

<https://www.hua.gr/index.php/el/>, in order to check its reliability in the TLS protocol.

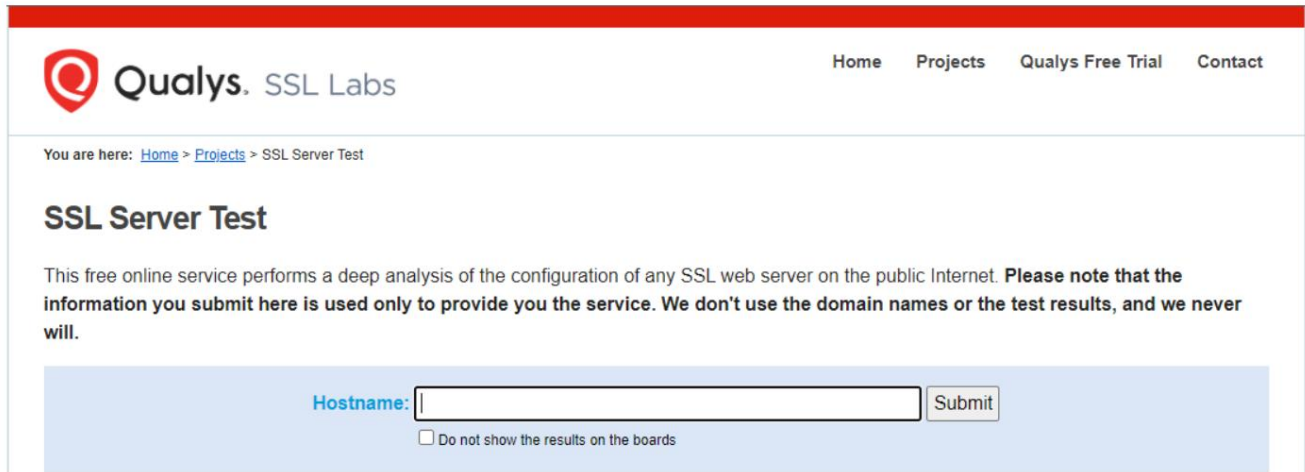


Figure 3.1. The university site of Harokopio

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

Research from the web tool

Initially, we used the web tool <https://www.ssllabs.com/ssltest/>.



The screenshot shows the Qualys SSL Labs website. At the top, there is a navigation bar with links: Home, Projects, Qualys Free Trial, and Contact. Below the navigation bar, the breadcrumb trail reads: You are here: Home > Projects > SSL Server Test. The main heading is "SSL Server Test". A paragraph of text states: "This free online service performs a deep analysis of the configuration of any SSL web server on the public Internet. Please note that the information you submit here is used only to provide you the service. We don't use the domain names or the test results, and we never will." Below this text is a form with a label "Hostname:" followed by a text input field and a "Submit" button. There is also a checkbox labeled "Do not show the results on the boards".

Figure 3.2. The SSL Labs web tool

We put the website URL in the Hostname field provided by the tool and saw the search results and the website's digital certificates in <https://www.ssllabs.com/ssltest/analyze.html?d=www.hua.gr>.

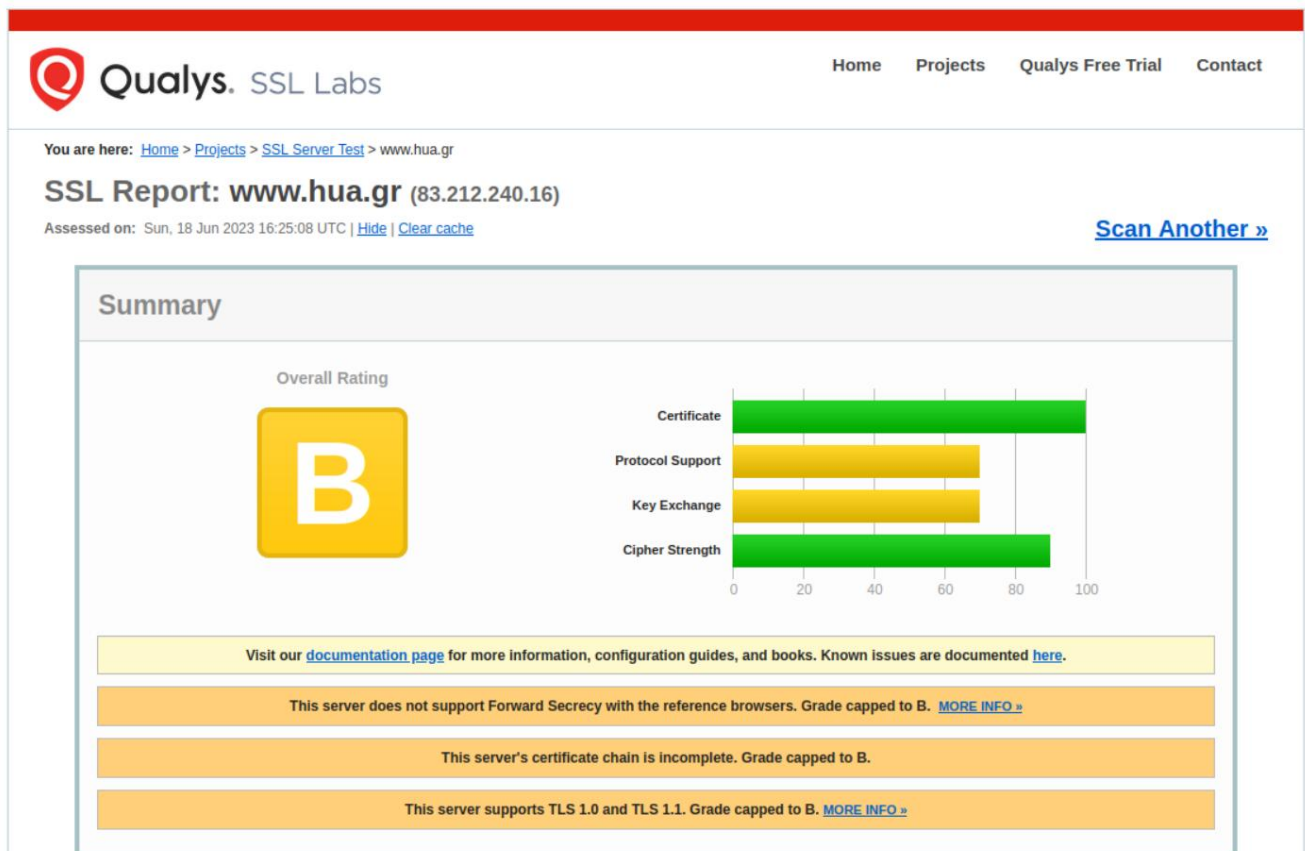


Figure 3.3. The results of the web tool survey

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

Certificate #1: RSA 2048 bits (SHA384withRSA)	
 Server Key and Certificate #1	
Subject	*.hua.gr Fingerprint SHA256: bbf619f1e9fd7564ca5a18715c9a52a51059ed6b5a616d58aeb2606a1e28d022 Pin SHA256: b0c1cSqJsn0NRPP98vvgQlp+RU8hOMo0n3YJLkwp+9l=
Common names	*.hua.gr
Alternative names	*.hua.gr hua.gr
Serial Number	4d8178c8ce7929ba601f2ccee62e0d8a
Valid from	Wed, 30 Nov 2022 00:00:00 UTC
Valid until	Thu, 30 Nov 2023 23:59:59 UTC (expires in 5 months and 12 days)
Key	RSA 2048 bits (e 65537)
Weak key (Debian)	No
Issuer	GEANT OV RSA CA 4 AIA: http://GEANT.crl.sectigo.com/GEANTOVRSA4.crl
Signature algorithm	SHA384withRSA
Extended Validation	No
Certificate Transparency	Yes (certificate)
OCSP Must Staple	No
Revocation information	CRL, OCSP CRL: http://GEANT.crl.sectigo.com/GEANTOVRSA4.crl OCSP: http://GEANT.ocsp.sectigo.com
Revocation status	Good (not revoked)
DNS CAA	No (more info)
Trusted	Yes Mozilla Apple Android Java Windows

Figure 3.4. The server's digital certificate

The research showed that the website's reliability grade for the TLS protocol is "B", which means that it presents a vulnerability, specifically in "Protocol Support" and "Key Exchange", which are in yellow (unlike the others which are green in the bar graph next to the grade). We looked for more information in the fields that say:

"The server does not support Forward Secrecy with the reference browsers. Grade capped to B. MORE INFO"

and specifically in the article https://blog.qualys.com/product-tech/2018/02/02/forward-secrecy-authenticated-encryption-and-robot-grading-update?_ga=2.218329754.2017122474.1687046115-1545449628.1687046115

"The server supports TLS 1.0 and TLS 1.1. Grade capped to B. MORE INFO"

and specifically in the article https://blog.qualys.com/product-tech/2017/03/13/caa-mandated-by-cabrowser-forum?_ga=2.204699411.2017122474.1687046115-1545449628.1687046115

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

SSL Labs Grade Change for TLS 1.0 and TLS 1.1 Protocols



Yash Sannegowda

November 19, 2018 - 4 min read

👍 49

Last updated on: December 16, 2022



Update 1/31/2020: The grade change is now live on www.ssllabs.com. Servers that support TLS 1.0 or TLS 1.1 are capped to B grade.

Update 1/16/2020: The grade change is now live on the development server at dev.ssllabs.com. Servers that support TLS 1.0 or TLS 1.1 are capped to B grade on the development server. Deployment to production SSL Labs servers is planned for the very end of January.

Update 10/11/19: The TLS 1.0/1.1 warning changes are now live on www.ssllabs.com. The grade change for supporting TLS 1.0/1.1 is changed from March 2020 to January 2020 as shown below in the "SSL Labs Grade Change" section below and as reflected in the summary messages in SSL Labs results.

Update 11/30/18: Now live on ssllabs.com: In Configuration->Protocols section "TLS 1.1" text color will be changed to Orange by end of November 2018.

Figure 3.5. Website vulnerability information in the "Protocol Support" field

The article mentions websites that support older versions of TLS that had some vulnerabilities, which have been fixed in the newer version, TLS 1.3. Hence the "B" grade from the research tool.

Penalty for not using forward secrecy (B)

Forward secrecy (FS) also known as perfect forward secrecy (PFS), is a property of secure communication protocols in which compromises of long-term keys does not compromise past session keys. Forward secrecy protects past sessions against future compromises of private key. The very popular RSA key exchange doesn't provide forward secrecy. You need to support and prefer ECDHE suites in order to enable forward secrecy with modern web browsers.

SSL Labs will start penalizing servers that don't support forward secrecy; Grade will be capped to B. We will not penalize sites that use suites without forward secrecy provided they are never negotiated with clients that can do better.

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

Penalty for not using AEAD suites (B)

Your site should use [secure cipher suites](#). AEAD is the only encryption approach without any known weaknesses. The alternative, CBC encryption, is susceptible to timing attacks (as implemented in TLS). AEAD suites provide strong authentication, key exchange, forward secrecy, and encryption of at least 128 bits. TLS 1.3 supports only AEAD suites. SSL Labs doesn't currently reward the use of AEAD suites. In this grading criteria update we will start requiring AEAD suites for A.

Grade will be capped to B, if AEAD suites are not supported. As with forward secrecy, we will not penalize sites if they continue to use non-AEAD suites provided AEAD suites are negotiated with clients that support them.

We have talked about these changes in [Announcing SSL Labs Grading Changes for 2017](#).

Penalty for ROBOT vulnerability (F)

Return Of Bleichenbacher Oracle Threat, is an attack model based on Daniel Bleichenbacher chosen-ciphertext attack. Bleichenbacher discovered an adaptive-chosen ciphertext attack against protocols using RSA, he demonstrated the ability to perform RSA private-key operations. Researchers have been able to exploit the same vulnerability with small variations to the Bleichenbacher attack.

SSL Labs will start giving "F" grade to the servers affected by ROBOT vulnerability from ~~February 28,~~ 2018 March 1, 2018. Note: All changes described in this blog post go live on March 1.

SSL Labs has started giving a warning if the site doesn't support forward secrecy and/or AEAD suites; or if the site is vulnerable to ROBOT.

Penalty for using Symantec Certificates (T)

Starting March 1, 2018, SSL Labs will give "T" grade for Symantec certificates issued before June 2016.

See details in [Google and Mozilla are Deprecating Existing Symantec Certificates](#).

Figure 3.6. Website vulnerability information in the "Key Exchange" field

The article mentions websites that have outdated certificates, which use old cryptographic algorithms during the client-server handshake. These algorithms are supported by old versions of TLS, which are naturally vulnerable. The result is that important information about the protocol communication is compromised.

Finally, we also saw the analysis of the protocol versions and cryptographic suites supported by this website.

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

		Protocols	
	TLS 1.3		No
	TLS 1.2		Yes
	TLS 1.1		Yes
	TLS 1.0		Yes
	SSL 3		No
	SSL 2		No
		Cipher Suites	
	# TLS 1.2 (server has no preference)		
	TLS_RSA_WITH_AES_128_CBC_SHA (0x2f)	WEAK	128
	TLS_DHE_RSA_WITH_AES_128_CBC_SHA (0x33)	DH 2048 bits FS WEAK	128
	TLS_RSA_WITH_CAMELLIA_128_CBC_SHA (0x41)	WEAK	128
	TLS_DHE_RSA_WITH_CAMELLIA_128_CBC_SHA (0x45)	DH 2048 bits FS WEAK	128
	TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA (0xc013)	ECDH secp256r1 (eq. 3072 bits RSA) FS WEAK	128
	TLS_RSA_WITH_AES_128_CBC_SHA256 (0x3c)	WEAK	128
	TLS_DHE_RSA_WITH_AES_128_CBC_SHA256 (0x67)	DH 2048 bits FS WEAK	128
	TLS_RSA_WITH_AES_128_GCM_SHA256 (0x9c)	WEAK	128
	TLS_DHE_RSA_WITH_AES_128_GCM_SHA256 (0x9e)	DH 2048 bits FS	128
	TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA256 (0xc027)	ECDH secp256r1 (eq. 3072 bits RSA) FS WEAK	128
	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 (0xc02f)	ECDH secp256r1 (eq. 3072 bits RSA) FS	128
	TLS_RSA_WITH_AES_256_CBC_SHA (0x35)	WEAK	256
	TLS_DHE_RSA_WITH_AES_256_CBC_SHA (0x39)	DH 2048 bits FS WEAK	256
	TLS_RSA_WITH_CAMELLIA_256_CBC_SHA (0x84)	WEAK	256
	TLS_DHE_RSA_WITH_CAMELLIA_256_CBC_SHA (0x88)	DH 2048 bits FS WEAK	256
	TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA (0xc014)	ECDH secp256r1 (eq. 3072 bits RSA) FS WEAK	256
	TLS_RSA_WITH_AES_256_CBC_SHA256 (0x3d)	WEAK	256
	TLS_DHE_RSA_WITH_AES_256_CBC_SHA256 (0x6b)	DH 2048 bits FS WEAK	256
	TLS_RSA_WITH_AES_256_GCM_SHA384 (0x9d)	WEAK	256
	TLS_DHE_RSA_WITH_AES_256_GCM_SHA384 (0x9f)	DH 2048 bits FS	256
	TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384 (0xc028)	ECDH secp256r1 (eq. 3072 bits RSA) FS WEAK	256
	TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 (0xc030)	ECDH secp256r1 (eq. 3072 bits RSA) FS	256

Figure 3.7. Analysis of protocol versions and cipher suites

Research from the installed tool

First, we opened the machine's terminal and moved to the directory where the python2 script is located with the command

```
cd a2sv
```

From Figure 3.3, we took the IP Address of the website and put it as a parameter to run the command:

```
python2 a2sv.py -t 83.212.240.16
```

Then, we saw the results of the research.

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

```
[A2SV REPORT]
[TARGET]: 83.212.240.16
[PORT]: 443
[SCAN TIME]: 2023-06-18 19:27:18.555361
[VULNERABILITY]
Vulnerability    CVE                CVSS v2 Base Score    State
=====
Anonymous Cipher CVE-2007-1858      AV:N/AC:H/Au:N/C:P/I:N/A:N Vulnerable!
CRIME(SPDY)      CVE-2012-4929      AV:N/AC:H/Au:N/C:P/I:N/A:N Vulnerable!
HeartBleed       CVE-2014-0160      AV:N/AC:L/Au:N/C:P/I:N/A:N Not Vulnerable.
CCS Injection    CVE-2014-0224      AV:N/AC:M/Au:N/C:P/I:P/A:P Not Vulnerable.
SSLv3 POODLE     CVE-2014-3566      AV:N/AC:M/Au:N/C:P/I:N/A:N Not Vulnerable.
OpenSSL FREAK    CVE-2015-0204      AV:N/AC:M/Au:N/C:N/I:P/A:N Not Vulnerable.
OpenSSL LOGJAM   CVE-2015-4000      AV:N/AC:M/Au:N/C:N/I:P/A:N Not Vulnerable.
SSLv2 DROWN     CVE-2016-0800      AV:N/AC:M/Au:N/C:P/I:N/A:N Not Vulnerable.
[FIN] Scan Finish!
```

Figure 3.8. The results of the summary survey of the installed tool

The research showed that the website is vulnerable to CRIME and Anonymous Cipher attacks, and this is due to the fact that it supports old versions of TLS. Finally, we saw the research's detailed checks for each type of attack that the tool checks for (CRIME, DROWN, FREAK, HeartBleed, LOGJAM).

```
GREEN
[INF] Check the SSL..
[RES] This target supports SSL..
[INF] Scan Anonymous Cipher..
- [LOG] IP Check Ok.
- [LOG] Start SSL Connection
- [LOG] Analysis SSL Information
- [LOG] 'Connection fail'
[INF] Scan CRIME(SPDY)..
- [LOG] IP Check Ok.
- [LOG] Start SSL Connection
- [LOG] Analysis SSL Information
- [LOG] 'Includes SPDY version <4'
[INF] Scan CCS Injection..
- [LOG] TLSv1.2 83.212.240.16:443 rejected early CCS
- [LOG] TLSv1.1 83.212.240.16:443 rejected early CCS
- [LOG] TLSv1 83.212.240.16:443 rejected early CCS
- [LOG] [SSLv3] 83.212.240.16:443 Invalid handshake.
[INF] Scan HeartBleed..
- [LOG] Sending Client Hello...
- [LOG] Waiting for Server Hello...
- [LOG] Sending heartbeat request..
[INF] Scan SSLv3 POODLE..
- [LOG] Invalid SSLv3 handshake.
[INF] Scan OpenSSL FREAK..
- [LOG] IP Check Ok.
- [LOG] Start SSL Connection / Gathering Information
- [LOG] Ending Get Information
- [LOG] 'Cipher is EXP' not in Response
[INF] Scan OpenSSL LOGJAM..
- [LOG] IP Check Ok.
- [LOG] Start SSL Connection / Gathering Information
- [LOG] Ending Get Information
- [LOG] 'Cipher is DEH' not in Response
[INF] Scan SSLv2 DROWN..
- [LOG] Not connected SSLv2
[RES] Finish scan all vulnerability..
```

Figure 3.9. The results of the analytical research of the installed tool

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

Agreements and disagreements of the tools

The web tool performs more extensive checks than the installed one, but both tools still agree that the website has vulnerabilities due to supporting older versions of TLS. However, the installed tool does not detect the vulnerability regarding the website certificate, as it only checks for vulnerabilities for specific types of attacks.

4. TLS Scanning of suspicious website

Web page

For the purpose of the activity, the suspicious website <https://www.blackboxresale.com/login.aspx> was used, in order to check its reliability in the TLS protocol.

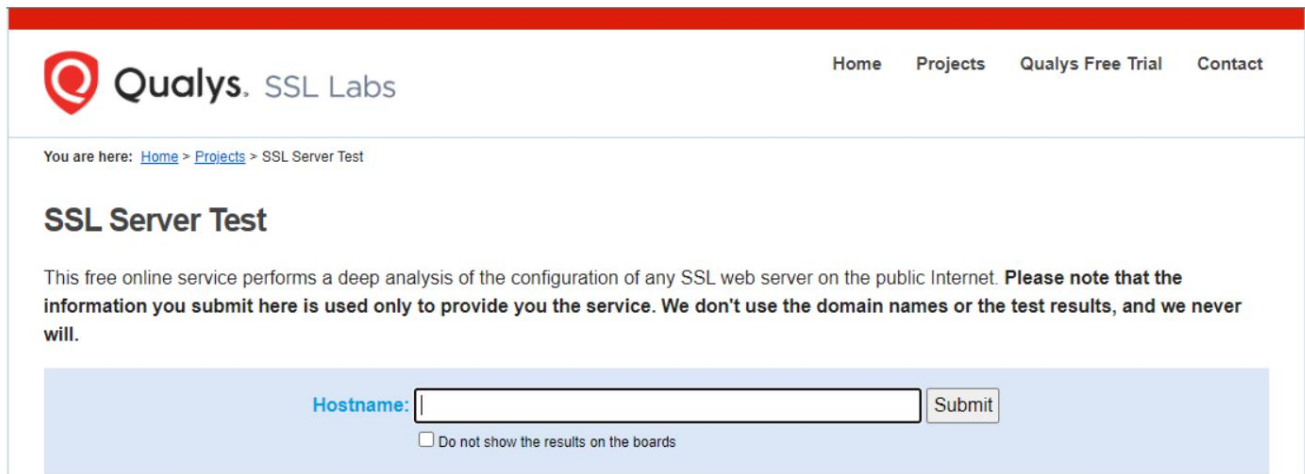
The screenshot displays the Black Box Resale Services website. The header includes the company logo, contact information (Call Us: 877-468-4237), and links for request quote, live chat, contact us, and your cart. A navigation menu lists Solutions, Store/Catalog, Sell to Us, Support, and About. Below the menu, there are links for Sales Services, Contact Us, FAQ's, Shipping Policy, Warranty Policy, Glossary of Terms, User Guides, and Request Quote. The main content area features a 'Login' section with fields for Username and Password, a 'login' button, and a link to 'Forgot Your Password? Click here'. To the right, there is a 'New Users' section with fields for Username, Email, First Name, Last Name, Password, Confirm Password, Password Hint, and Password Answer, along with a 'create new' button. The footer contains four columns: 'Connect' (Get in touch and stay in touch with Black Box Resale Services, Contact Us, Find your Sales Representative, Sign up for our Newsletter), 'Explore' (Black Box Resale Services offers budget-friendly communications solutions guaranteed to perform, Repair Services, Infrastructure Solutions), 'Shop' (Save up to 60% on refurbished and new-in-time telephones, cordless systems, headsets, conference phones, and wireless/mobile equipment, Netel), and 'About' (Black Box Resale Services helps customers substantially reduce telephony hardware expenses, provides streamlined product sourcing, and guarantees peace of mind).

Figure 4.1. The suspicious website

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

Research from the web tool

Initially, we used the web tool <https://www.ssllabs.com/ssltest/>.



The screenshot shows the Qualys SSL Labs website. The header includes the Qualys logo and navigation links: Home, Projects, Qualys Free Trial, and Contact. Below the header, the breadcrumb trail reads: You are here: Home > Projects > SSL Server Test. The main heading is "SSL Server Test". A paragraph explains the service: "This free online service performs a deep analysis of the configuration of any SSL web server on the public Internet. Please note that the information you submit here is used only to provide you the service. We don't use the domain names or the test results, and we never will." Below this is a form with a "Hostname:" label, a text input field, and a "Submit" button. A checkbox labeled "Do not show the results on the boards" is located below the input field.

Figure 4.2. The SSL Labs web tool

We put the website URL in the Hostname field provided by the tool and saw the search results and the website's digital certificates in

<https://www.ssllabs.com/ssltest/analyze.html?d=www.blackboxresale.com&fbclid=IwAR1eBgjHPYkoODEGkYQ8QZpCsFtKTJQ2H6Ws0XfFWynWe4zEwSQTUk2InMA>.

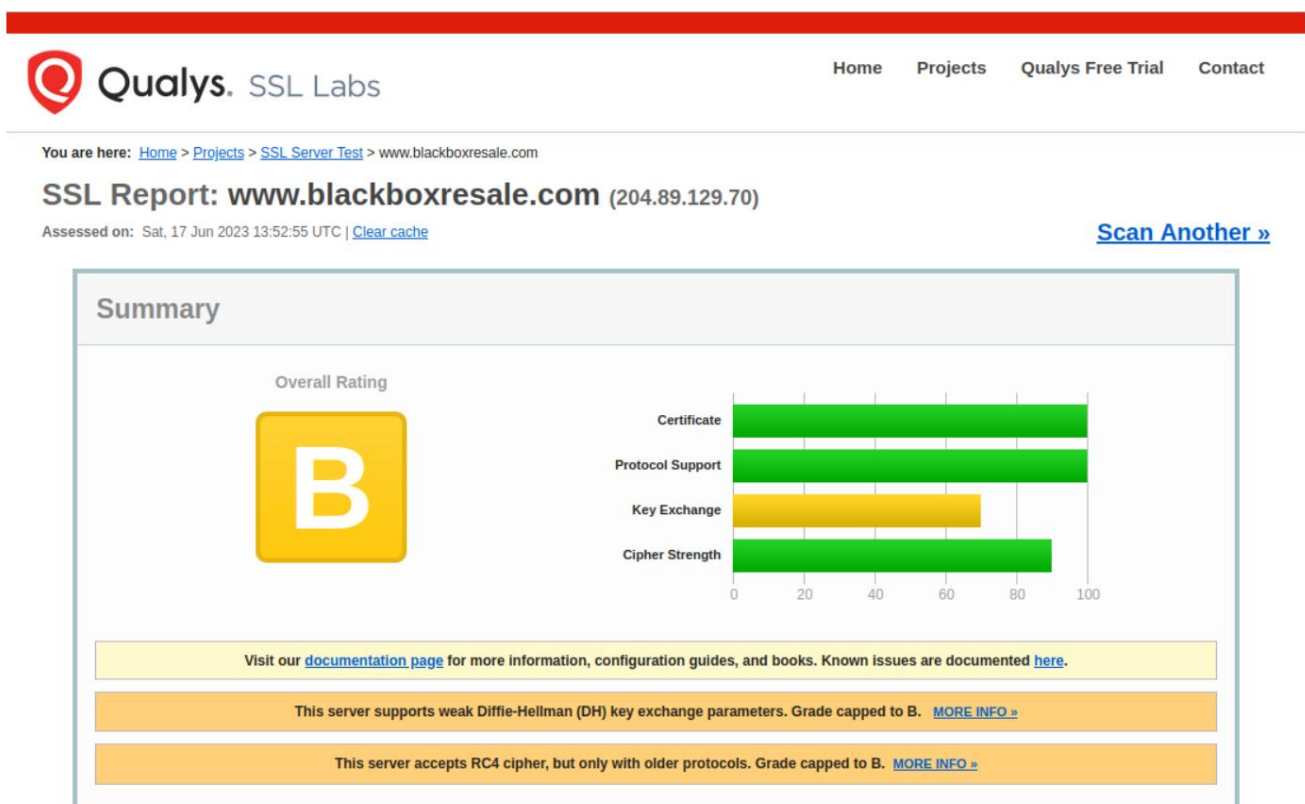


Figure 4.3. The results of the web tool survey

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

Certificate #1: RSA 2048 bits (SHA256withRSA)	
 Server Key and Certificate #1	
Subject	blackboxresale.com Fingerprint SHA256: 18449296cf7bb82d47d73ed6feb2f8a82b43fb0d21fb31cd82fd88090acb1149 Pin SHA256: n3ql14Jais/c8Z5pSCqqa7QhLMC6w1aEJYEwJec9N+Q=
Common names	blackboxresale.com
Alternative names	blackboxresale.com www.blackboxresale.com
Serial Number	2bf3c5d657423d7e
Valid from	Wed, 07 Sep 2022 22:55:50 UTC
Valid until	Thu, 07 Sep 2023 22:55:50 UTC (expires in 2 months and 20 days)
Key	RSA 2048 bits (e 65537)
Weak key (Debian)	No
Issuer	Go Daddy Secure Certificate Authority - G2 AIA: http://certificates.godaddy.com/repository/gdig2.crt
Signature algorithm	SHA256withRSA
Extended Validation	No
Certificate Transparency	Yes (certificate)
OCSP Must Staple	No
Revocation information	CRL, OCSP CRL: http://crl.godaddy.com/gdig2s1-4470.crl OCSP: http://ocsp.godaddy.com/
Revocation status	Good (not revoked)
DNS CAA	No (more info)
Trusted	Yes Mozilla Apple Android Java Windows

Figure 4.4. The server's digital certificate

The research showed that the website's reliability grade for the TLS protocol is "B", which means that it presents a vulnerability, specifically in the "Key Exchange" section, which is colored yellow (unlike the others, which are green in the bar graph next to the grade). We searched for more information in the fields that say:

"The server supports weak Diffie-Hellman (DH) key exchange parameters. Grade capped to B. MORE INFO" and specifically in the article https://weakdh.org/?fbclid=IwAR1ozN1YuPSuKUzGyWoNb_grZ5nh-k3qyNUVWI_2oNXNOVCraxFz4eN9H-E

"This server accepts RC4 cipher, but only with older protocols. Grade capped to B. MORE INFO" and specifically in the article https://blog.qualys.com/product-tech/2013/03/19/rc4-in-tls-is-broken-now-what?_ga=2.217224725.2017122474.1687046115-1545449628.1687046115&fbclid=IwAR2bRWWSBzEd3dVnRd29X65jjsSRt2RPu5kiy6AZVza2QBuklcWXj_JkL-1w

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

Weak Diffie-Hellman and the Logjam Attack

Diffie-Hellman key exchange is a popular cryptographic algorithm that allows Internet protocols to agree on a shared key and negotiate a secure connection. It is fundamental to many protocols including HTTPS, SSH, IPsec, SMTPS, and protocols that rely on TLS.

We have uncovered several weaknesses in how Diffie-Hellman key exchange has been deployed:

1. **Logjam attack against the TLS protocol.** The Logjam attack allows a man-in-the-middle attacker to downgrade vulnerable TLS connections to 512-bit export-grade cryptography. This allows the attacker to read and modify any data passed over the connection. The attack is reminiscent of the [FREAK attack](#), but is due to a flaw in the TLS protocol rather than an implementation vulnerability, and attacks a Diffie-Hellman key exchange rather than an RSA key exchange. The attack affects any server that supports DHE_EXPORT ciphers, and affects all modern web browsers. 8.4% of the Top 1 Million domains were initially vulnerable.

2. **Threats from state-level adversaries.** Millions of HTTPS, SSH, and VPN servers all use the same prime numbers for Diffie-Hellman key exchange. Practitioners believed this was safe as long as new key exchange messages were generated for every connection. However, the first step in the number field sieve—the most efficient algorithm for breaking a Diffie-Hellman connection—is dependent only on this prime. After this first step, an attacker can quickly break individual connections.

We carried out this computation against the most common 512-bit prime used for TLS and demonstrate that the Logjam attack can be used to downgrade connections to 80% of TLS servers supporting DHE_EXPORT. We further estimate that an academic team can break a 768-bit prime and that a nation-state can break a 1024-bit prime. Breaking the single, most common 1024-bit prime used by web servers would allow passive eavesdropping on connections to 18% of the Top 1 Million HTTPS domains. A second prime would allow passive decryption of connections to 66% of VPN servers and 26% of SSH servers. A close reading of published NSA leaks shows that the agency's attacks on VPNs are consistent with having achieved such a break.

Figure 4.6. Website vulnerability information in the “Key Exchange” field

[← Blog Home](#)

RC4 in TLS is Broken: Now What?



Ivan Ristic

March 19, 2013 - 4 min read

10

Last updated on: December 15, 2022

RC4 has long been considered problematic, but until very recently there was no known way to exploit the weaknesses. After the BEAST attack was disclosed in 2011, we—grudgingly—started using RC4 in order to avoid the vulnerable CBC suites in TLS 1.0 and earlier. This caused the usage of RC4 to increase, and some say that it now accounts for about 50% of all TLS traffic.

Last week, a group of researchers (Nadhem AlFardan, Dan Bernstein, Kenny Paterson, Bertram Poettering and Jacob Schuld) [announced significant advancements in the attacks against RC4](#), unveiling new weaknesses as well as new methods to exploit them. Matthew Green has a [great overview](#) on his blog, and here are the [slides](#) from the talk where the new issues were announced.

At the moment, the attack is not yet practical because it requires access to millions and possibly billions of copies of the same data encrypted using different keys. A browser would have to make that many connections to a server to give the attacker enough data. A possible exploitation path is to somehow instrument the browser to make a large number of connections, while a man in the middle is observing and recording the traffic.

We are still safe at the moment, but there is a tremendous incentive for researchers to improve the attacks on RC4, which means that we need to act swiftly.

Figure 4.7. Information about the website vulnerability in the “Key Exchange” field

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

The articles report that websites that support old versions of TLS use old cryptographic algorithms that have vulnerabilities. The result is that important information regarding the protocol communication is compromised.

Finally, we also saw the analysis of the protocol versions and cryptographic suites supported by this website.

		Protocols	
TLS 1.3			No
TLS 1.2			Yes
TLS 1.1			No
TLS 1.0			No
SSL 3			No
SSL 2			No

		Cipher Suites	
# TLS 1.2 (suites in server-preferred order)			
TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384 (0xc028)	ECDH secp256r1 (eq. 3072 bits RSA) FS	WEAK	256
TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA256 (0xc027)	ECDH secp256r1 (eq. 3072 bits RSA) FS	WEAK	128
TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA (0xc014)	ECDH secp256r1 (eq. 3072 bits RSA) FS	WEAK	256
TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA (0xc013)	ECDH secp256r1 (eq. 3072 bits RSA) FS	WEAK	128
TLS_DHE_RSA_WITH_AES_256_GCM_SHA384 (0x9f)	DH 1024 bits FS	WEAK	256
TLS_DHE_RSA_WITH_AES_128_GCM_SHA256 (0x9e)	DH 1024 bits FS	WEAK	128
TLS_RSA_WITH_AES_256_GCM_SHA384 (0x9d)		WEAK	256
TLS_RSA_WITH_AES_128_GCM_SHA256 (0x9c)		WEAK	128
TLS_RSA_WITH_AES_256_CBC_SHA256 (0x3d)		WEAK	256
TLS_RSA_WITH_AES_128_CBC_SHA256 (0x3c)		WEAK	128
TLS_RSA_WITH_AES_256_CBC_SHA (0x35)		WEAK	256
TLS_RSA_WITH_AES_128_CBC_SHA (0x2f)		WEAK	128
TLS_RSA_WITH_RC4_128_SHA (0x5)		INSECURE	128
TLS_RSA_WITH_RC4_128_MD5 (0x4)		INSECURE	128

Figure 4.8. Analysis of protocol versions and cipher suites

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

 Protocol Details	
Unable to perform this test due to an internal error. (1) For a better understanding of this test, please read this longer explanation (2) Key usage data kindly provided by the Censys network search engine; original DROWN website here (3) Censys data is only indicative of possible key and certificate reuse; possibly out-of-date and not complete	
DROWN	INTERNAL ERROR: connect timed out INTERNAL ERROR: connect timed out
Secure Renegotiation	Supported
Secure Client-Initiated Renegotiation	No
Insecure Client-Initiated Renegotiation	No
BEAST attack	Mitigated server-side (more info)
POODLE (SSLv3)	No, SSL 3 not supported (more info)
POODLE (TLS)	No (more info)
Zombie POODLE	No (more info) TLS 1.2 : 0xc027
GOLDENDOODLE	No (more info) TLS 1.2 : 0xc027
OpenSSL 0-Length	No (more info) TLS 1.2 : 0xc027
Sleeping POODLE	No (more info) TLS 1.2 : 0xc027
Downgrade attack prevention	Unknown (requires support for at least two protocols, excl. SSL2)
SSL/TLS compression	No
RC4	Yes INSECURE (more info)
Heartbeat (extension)	No
Heartbleed (vulnerability)	No (more info)
Ticketbleed (vulnerability)	No (more info)
OpenSSL CCS vuln. (CVE-2014-0224)	No (more info)
OpenSSL Padding Oracle vuln. (CVE-2016-2107)	No (more info)
ROBOT (vulnerability)	No (more info)
Forward Secrecy	Weak key exchange WEAK
ALPN	No
NPN	No
Session resumption (caching)	No (IDs assigned but not accepted)
Session resumption (tickets)	No
OCSP stapling	Yes

Figure 4.9. Analysis of protocol details

The image above confirms that personal data is indeed being leaked in the same period of time as users enter this website, as the RC4 cryptographic algorithm is no longer secure.

Research from the installed tool

First, we opened the machine's terminal and moved to the directory where the python2 script is located with the command

```
cd a2sv
```

From Figure 4.3, we took the IP Address of the website and put it as a parameter to run the command:

```
python2 a2sv.py -t 204.89.129.70
```

Then, we saw the results of the research.

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

```

GREEN
[INF] Check the SSL..
[RES] This target supports SSL..
[INF] Scan Anonymous Cipher..
- [LOG] IP Check Ok.
- [LOG] Start SSL Connection
- [LOG] Analysis SSL Information
- [LOG] 'Connection success'
[INF] Scan CRIME(SPDY)..
- [LOG] IP Check Ok.
- [LOG] Start SSL Connection
- [LOG] Analysis SSL Information
- [LOG] 'Includes SPDY version <4'
[INF] Scan CCS Injection..
- [LOG] [TLSv1.2] 204.89.129.70:443 Invalid handshake.
- [LOG] [TLSv1.1] 204.89.129.70:443 Invalid handshake.
- [LOG] [TLSv1] 204.89.129.70:443 Invalid handshake.
- [LOG] [SSLv3] 204.89.129.70:443 Invalid handshake.
[INF] Scan HeartBleed..
- [LOG] Sending Client Hello...
- [LOG] Waiting for Server Hello...
Traceback (most recent call last):
  File "../a2sv/a2sv.py", line 421, in <module>
    runScan(checkVun)
  File "../a2sv/a2sv.py", line 177, in runScan
    heartbleed_result = m_heartbleed_run(targetIP,port,displayMode)
  File "/home/tiger/a2sv/module/M_heartbleed.py", line 196, in m_heartbleed_run
    check(target,port,"","","",displayMode)
  File "/home/tiger/a2sv/module/M_heartbleed.py", line 172, in check
    version = parseresp(s)
  File "/home/tiger/a2sv/module/M_heartbleed.py", line 136, in parseresp
    typ, ver, pay = recvmsg(s)
  File "/home/tiger/a2sv/module/M_heartbleed.py", line 83, in recvmsg
    hdr = recvall(s, 5)
  File "/home/tiger/a2sv/module/M_heartbleed.py", line 74, in recvall
    data = s.recv(remain)
socket.error: [Errno 104] Connection reset by peer

```

Figure 4.9. The results of the summary survey of the installed tool

The investigation showed that the server does not respond to the Heartbeat Request sent by the client, resulting in the SSL/TLS connection being interrupted (hence the socket.error error).

Agreements and disagreements of the tools

The web tool performs more extensive checks than the installed one, but both tools still agree that the website has vulnerabilities due to supporting older versions of TLS. However, the installed tool does not detect the vulnerability regarding the insecurity of the RC4 cryptographic algorithm.

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ



Thank you for your attention. Ευχαριστώ σας.

